

DOMAIN 2

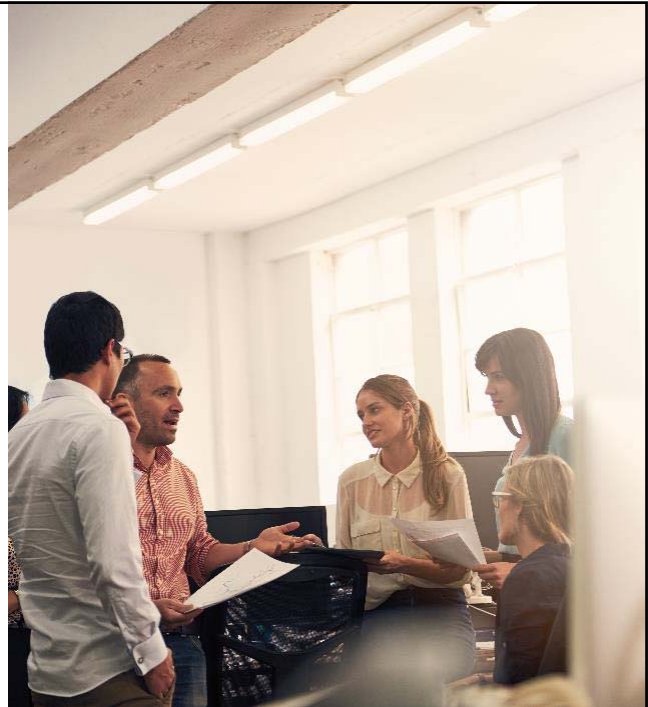
GOVERNANCE AND MANAGEMENT OF IT

1

DOMAIN 2

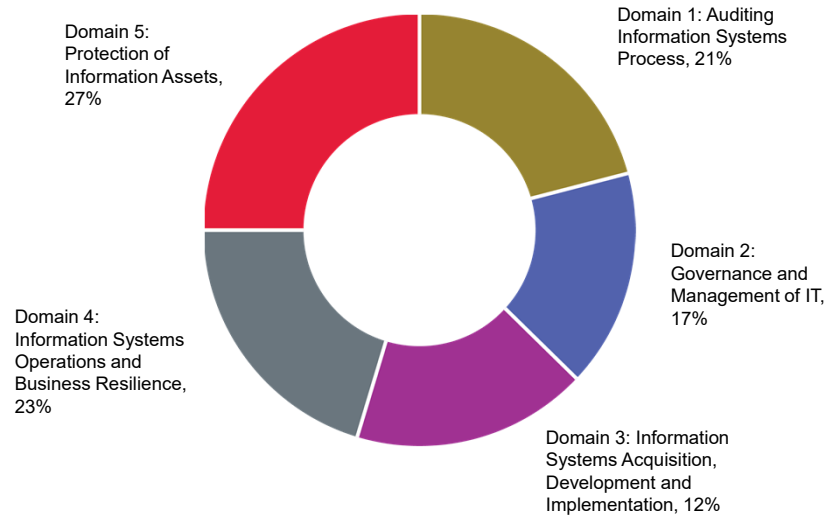
Governance and management of IT is an integral part of enterprise governance. Effective governance and management of IT consists of the leadership and organizational structures and processes that ensure that the enterprise's IT sustains and extends the enterprise's strategy and objectives.

Knowledge of IT governance is fundamental to the work of the IS auditor, and it forms the foundation for the development of sound control practices and mechanisms for management oversight and review.



2

ON THE CISA EXAM



ISACA

3

DOMAIN 2 OBJECTIVES

Upon completion of this domain an IS auditor should be able to:

- Evaluate the IT strategy for alignment with the organization's strategies and objectives.
- Evaluate the effectiveness of IT governance structure and IT organizational structure.
- Evaluate the organization's management of IT policies and practices.
- Evaluate the organization's IT policies and practices for compliance with regulatory and legal requirements.
- Evaluate IT resource and portfolio management for alignment with the organization's strategies and objectives.
- Evaluate the organization's risk management policies and practices.
- Evaluate IT management and monitoring of controls.



4

DOMAIN 2 OBJECTIVES

- Evaluate the monitoring and reporting of IT key performance indicators (KPIs).
- Evaluate whether IT supplier selection and contract management processes align with business requirements.
- Evaluate whether IT service management practices align with business requirements.
- Conduct periodic review of information systems and enterprise architecture. Evaluate data governance policies and practices.
- Evaluate the information security program to determine its effectiveness and alignment with the organization's strategies and objectives.
- Evaluate potential opportunities and threats associated with emerging technologies, regulations, and industry practices.



5

DOMAIN 2 TOPICS

IT Governance

- IT Governance and IT Strategy
- IT-Related Frameworks
- IT Standards, Policies, and Procedures
- Organizational Structure
- Enterprise Architecture
- Enterprise Risk Management
- Maturity Models
- Laws, Regulations, and Industry Standards Affecting the Organization

IT Management

- IT Resource Management
- IT Service Provider Acquisition and Management
- IT Performance Monitoring and Reporting
- Quality Assurance and Quality Management of IT

6

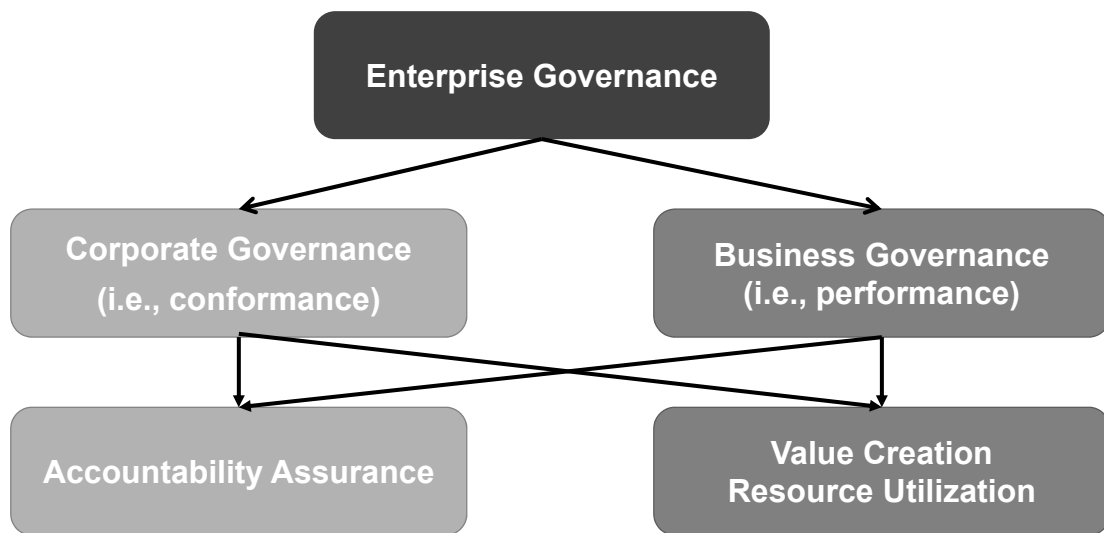
ISACA

6

IT GOVERNANCE AND IT STRATEGY

7

IT GOVERNANCE AND IT STRATEGY



8

ENTERPRISE GOVERNANCE OF INFORMATION AND TECHNOLOGY (EGIT)

The purpose of EGIT is to direct IT endeavors to ensure that IT aligns with and supports the enterprise's objectives and its realization of promised benefits.

Additionally, IT should enable the enterprise by exploiting opportunities and maximizing benefits. IT resources should be used responsibly, and IT-related risk should be managed appropriately.

ISACA

9

OUTCOMES OF EFFECTIVE INFORMATION SECURITY GOVERNANCE

IT resource management

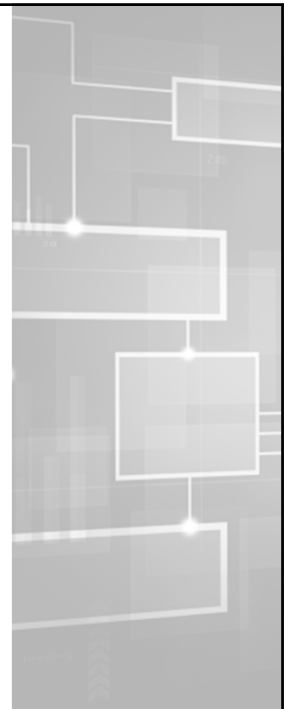
- Focuses on maintaining an updated inventory of all IT resources and addresses the risk management process

Performance measurement

- Focuses on ensuring that all IT resources perform as expected to deliver value to the business and identify risk early on. This process is based on performance indicators that are optimized for value delivery and from which any deviation might lead to risk.

Compliance management

- Focuses on implementing processes that address legal and regulatory policy and contractual compliance requirements



10

EGIT GOOD PRACTICES

1. Business managers and boards demanding a better return from IT investments.
2. Concern over the generally increasing level of IT expenditure
3. The need to meet regulatory requirements for IT controls in areas such as privacy and financial reporting and in specific sectors such as finance, pharmaceuticals and health care
4. The selection of service providers and the management of service outsourcing and acquisition
5. IT governance initiatives that include adoption of control frameworks and good practices to help monitor and improve critical IT activities to increase business value and reduce business risk
6. The need to optimize costs by following, where possible, standardized rather than specially developed approaches
7. The growing maturity and consequent acceptance of well-regarded frameworks
8. The need for enterprises to assess how they are performing against generally accepted standards and their peers

ISACA

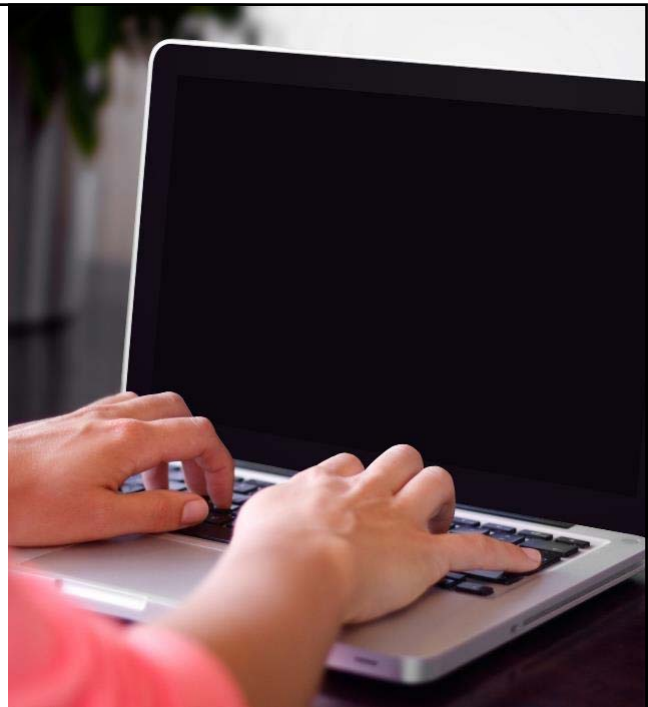
11

THE ROLE OF AUDIT IN EGIT

Audit plays a significant role in the implementation of EGIT.

It offers these benefits:

- Provides leading practice recommendations to senior management
- Helps ensure compliance with EGIT initiatives
- Provides independent and balanced view to facilitate quantitative improvement of IT processes



12

AREAS OF EGIT AUDIT

In accordance with the define role of the IS auditor, the following aspects of EGIT must be assessed:

- Alignment of enterprise governance and EGIT
- Alignment of the IT function with the organizational mission, vision, values, objectives and strategies
- Achievement of performance objectives
- Compliance with legal, environmental, fiduciary, security and privacy requirements
- The control environment of the organization, the inherent risk present, and IT investment and expenditure

ISACA

13

INFORMATION SECURITY GOVERNANCE

An information security governance framework generally consists of:

- A comprehensive security strategy intrinsically linked with business objectives
- Governing security policies that address each aspect of strategy, controls and regulation
- A complete set of standards for each policy to ensure that procedures and guidelines comply with policy
- An effective security organizational structure void of conflicts of interest
- Institutionalized monitoring processes to ensure compliance and provide feedback on effectiveness

14



14

EFFECTIVE INFORMATION SECURITY GOVERNANCE

- Maintain high quality information to support business decisions
- Generate business value from IT-enabled investments
- Achieve operational excellence through the reliable and efficient application of technology
- Maintain IT-related risk at an acceptable level
- Optimize the cost of IT services and technology
- Comply with ever-increasing relevant laws, regulations, contractual agreements and policies

15



15

OUTCOMES OF EFFECTIVE INFORMATION SECURITY GOVERNANCE



**Performance
Measurement**



**Resource
Management**



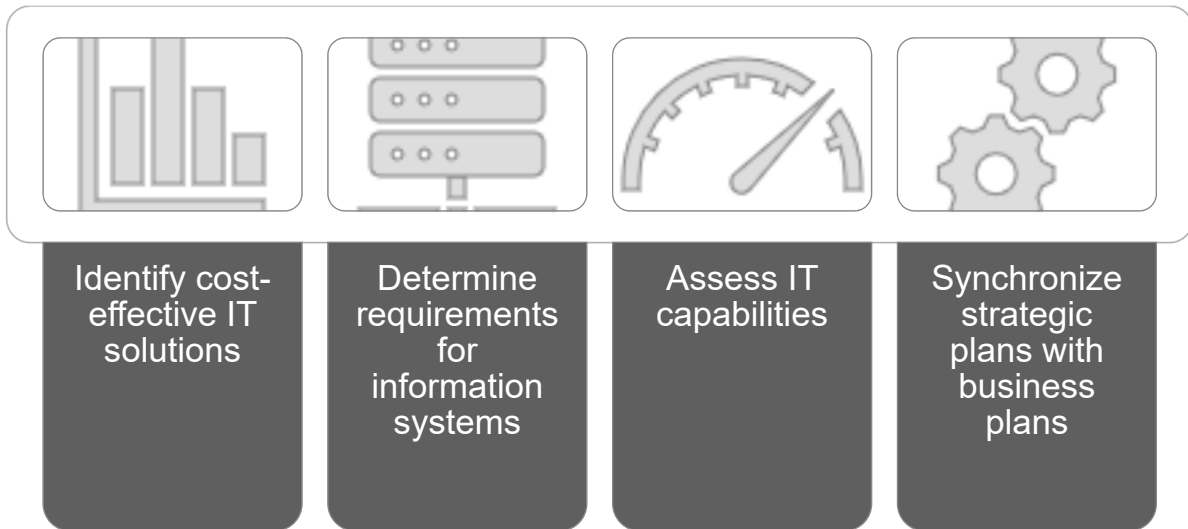
Process Integration

16

ISACA

16

STRATEGIC PLANNING



17

ISACA

17

BUSINESS INTELLIGENCE

Typical areas of measurement include:

- Process cost, efficiency and quality
- Customer satisfaction with product and service offerings
- Customer profitability, including determination of which attributes are useful predictors of customer profitability
- Staff and business unit achievement of key performance indicators
- Risk management

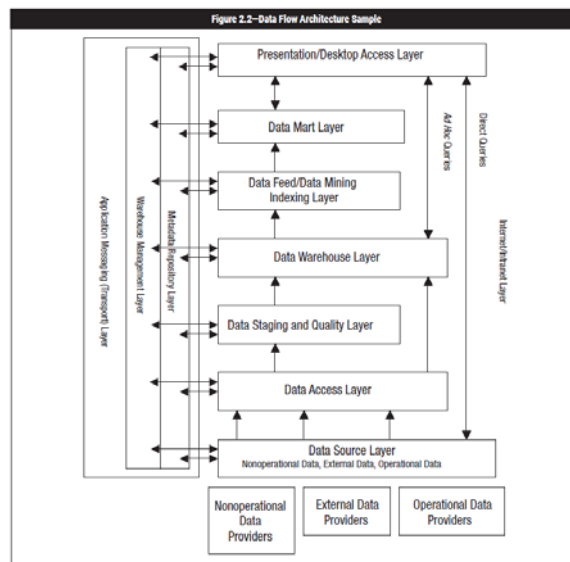
Business intelligence (BI) is a broad field of IT that encompasses the collection and analysis of information to assist decision making and assess organizational performance.

18

ISACA

18

BI DATA FLOW ARCHITECTURE



ISACA

19

ACTIVITY

In order to maximize the corporate focus on core operations, the CIO is looking to move several key enterprise application suites to the cloud. These application suites support operations that cross international boundaries and contain personally identifiable information and intellectual property.

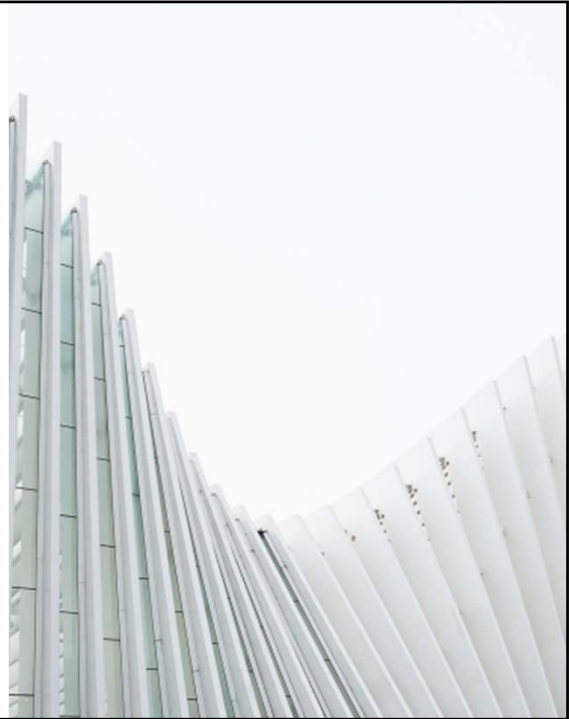
When looking at how the corporation addresses confidentiality of data being stored by the cloud services provider, what are some important governance areas to be considered?

20

DISCUSSION QUESTION

An IS auditor is evaluating the IT governance framework of an organization. Which of the following would be the **GREATEST** concern?

- A. Senior management has limited involvement.
- B. Return on investment (ROI) is not measured.
- C. Chargeback of IT cost is not consistent.
- D. Risk appetite is not quantified.

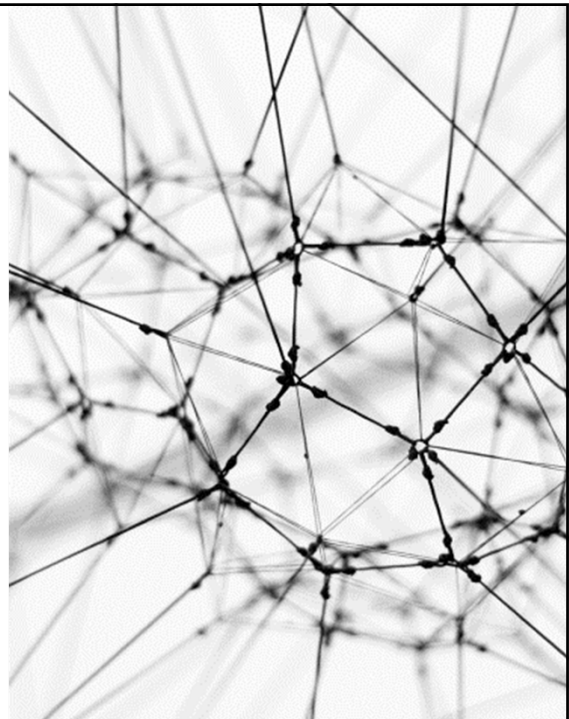


21

DISCUSSION QUESTION

Which of the following IT governance good practices improves strategic alignment?

- A. Supplier and partner risk is managed.
- B. A knowledge base on customers, products, markets and processes is in place.
- C. A structure is provided that facilitates the creation and sharing of business information.
- D. Top management mediates between the imperatives of business and technology.



22

IT-RELATED FRAMEWORKS

ISACA

23

EGIT FRAMEWORKS

Several frameworks provide standards for EGIT, including:

- COBIT
- International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 27000
- Information Technology Infrastructure Library (ITIL®)
- Open Information Security Management Maturity Model (O-ISM3)
- ISO/IEC 38500:2015: Information technology—Governance of IT for the organization
- ISO/IEC 20000
- ISO 3100:2018: Risk management—Guidelines

The key to maximizing value is to consider EGIT synergistically in the overall enterprise governance hierarchy.

ISACA

24

IT STANDARDS, POLICIES AND PROCEDURES

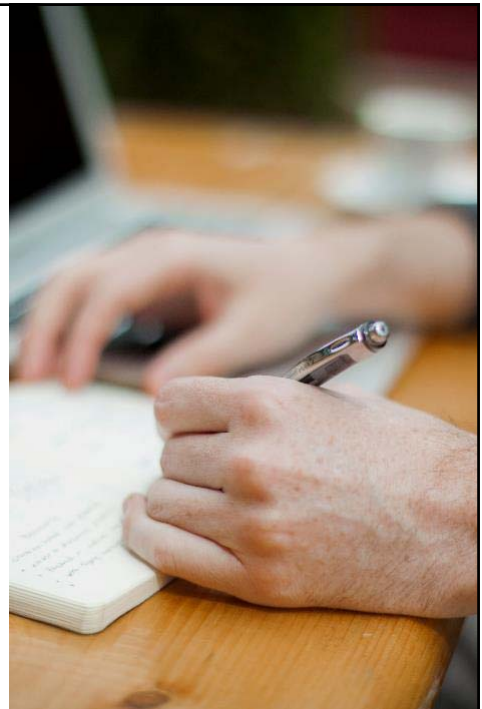
ISACA

25

STANDARDS

A standard is a mandatory requirement, code of practice or specification approved by a recognized external standards organization.

Professional standards refer to standards issued by professional organizations, such as ISACA, and related guidelines and techniques that assist the professional in implementing and complying with other standards.



26

POLICIES

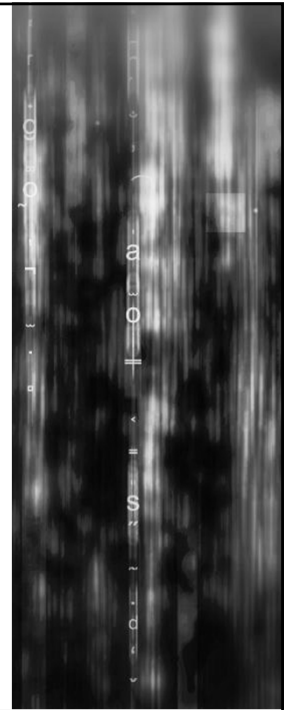
Policies are the high-level statements of management intent, expectations and direction.

Well-developed high-level policies in a mature organization can remain static for extended periods.

Management should review all policies periodically.

IS auditors should understand that policies are a part of the audit scope and test the policies for compliance.

IS controls should flow from the enterprise's policies and IS auditors should use policies as a benchmark for evaluating compliance.



27

INFORMATION SECURITY POLICY

A security policy for information and related technology is a first step toward building the security infrastructure for technology-driven organizations.

It communicates a coherent security standard to users, management and technical staff.

This policy should be used by IS auditors as a reference framework for performing audit assignments.

The adequacy and appropriateness of the policy is also an area of review during an IS audit.

ISACA

28

POLICY COMPONENTS

The information security policy may comprise a set of policies, generally addressing the following concerns:

- High-level information security policy — Includes statements on confidentiality, integrity and availability
- Data classification policy — Provides classifications and levels of control at each classification
- End-user computing policy — Identifies the parameters and usage of desktop, mobile and other tools
- Access control policy — Describes methods for defining and granting access to users of various IT resources
- Acceptable use policy (AUP) — Controls the use of information system resources through defining how IT resources may be used by employees

ISACA

29

PROCEDURES

The documented, defined steps in procedures aid in achieving policy objectives.

Procedures documenting business and aligned IT processes and their embedded controls are formulated by process owners.

To be effective, procedures must:

- Be frequently reviewed and updated
- Be communicated to those affected by them

An IS auditor examines procedures to identify and evaluate controls to ensure that control objectives are met.

ISACA

30

GUIDELINES

Guidelines for executing procedures are also the responsibility of operations.

Guidelines should contain information that will be helpful in executing the procedures. Including clarification of:

- Policies and standards
- Dependencies
- Suggestions and examples
- Narrative clarifying the procedures
- Background information that may be useful
- And tools that can be used

31

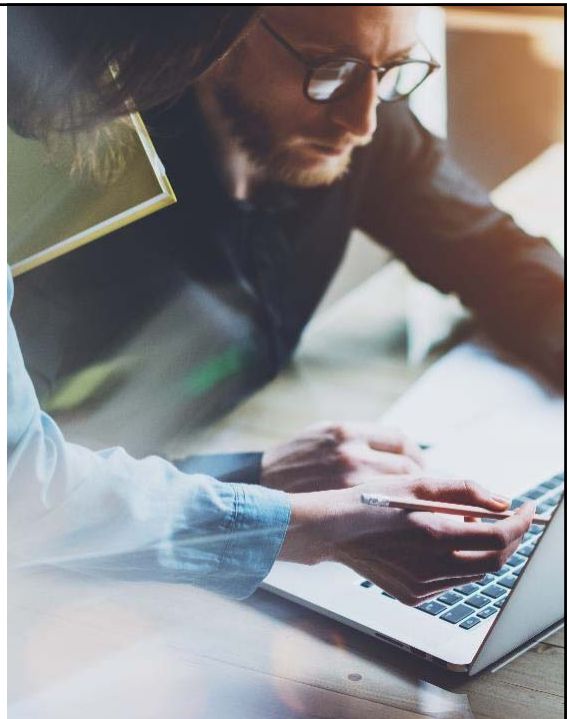
ISACA

31



ACTIVITY

In evaluating IT strategy, would policies or procedures be more helpful in ensuring ongoing alignment of IT strategy with the organization's specific objectives and business initiatives?

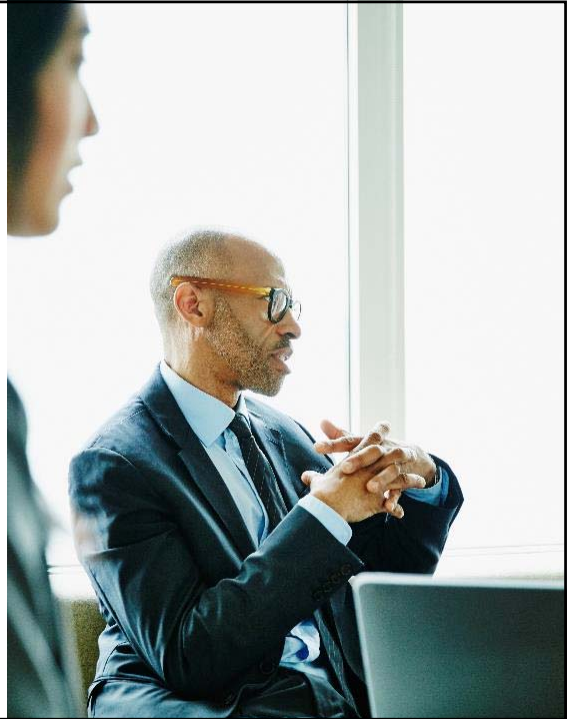


32

DISCUSSION QUESTION

When auditing the IT governance framework and IT risk management practices that exist within an organization, the IS auditor identified some undefined responsibilities regarding IT management and governance roles. Which of the following recommendations is the **MOST** appropriate?

- A. Review the strategic alignment of IT with the business.
- B. Recommend accountability rules within the organization.
- C. Ensure that independent IS audits are conducted periodically.
- D. Create a chief risk officer (CRO) role in the organization.

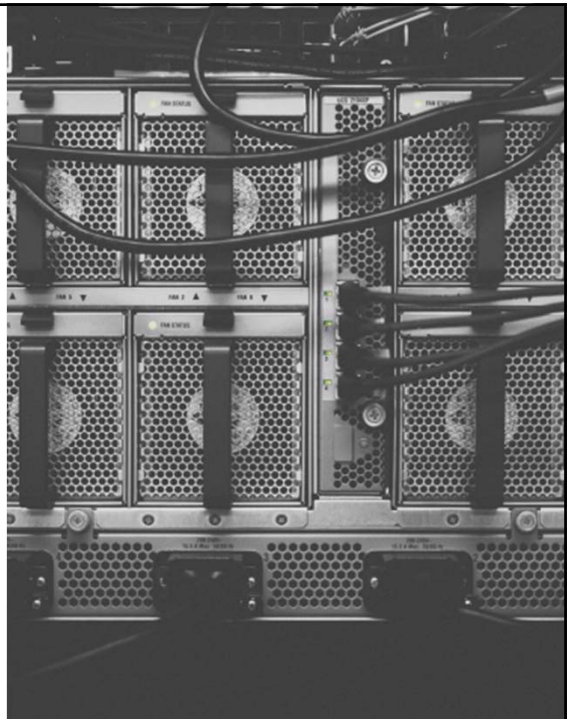


33

DISCUSSION QUESTION

When auditing the onsite archiving process of emails, the IS auditor should pay the **MOST** attention to:

- A. the existence of a data retention policy.
- B. the storage capacity of the archiving solution.
- C. the level of user awareness concerning email use.
- D. the support and stability of the archiving solution manufacturer.



34

ORGANIZATIONAL STRUCTURE

ISACA

35

ORGANIZATIONAL STRUCTURE

Organizational structure is a key component to governance. They provide the key decision-making entities in an enterprise. The following section provides guidance for organizational structures and roles and responsibilities within EGIT.

Keep in mind that the actual structure may differ depending on the size, industry and location of an enterprise.

ISACA

36

IT GOVERNING COMMITTEES

Organizations often have executive-level strategy and steering committees to handle organization-wide IT issues.

The IS auditor should know the responsibilities of, authority possessed by and membership of such committees.

ISACA

37

IT COMMITTEE ANALYSIS

Level	IT Strategy Committee	IT Steering Committee
Responsibility	Provides insight and advice to the board across a range of IT topics	Decides the level and allocation of IT spending, aligns and approves the enterprise's IT architecture, and other oversight functions.
Authority	Advises the board and management on IT strategy, focusing on current and future strategic IT issues	Assists the executive in the delivery of IT strategy, overseeing management of IT service delivery, projects and implementation
Membership	Includes board members and specialist non-board members	Includes sponsoring executive, business executive (key users), chief information officer (CIO) and key advisors, as required

ISACA

38

MATRIX OF OUTCOMES AND RESPONSIBILITIES

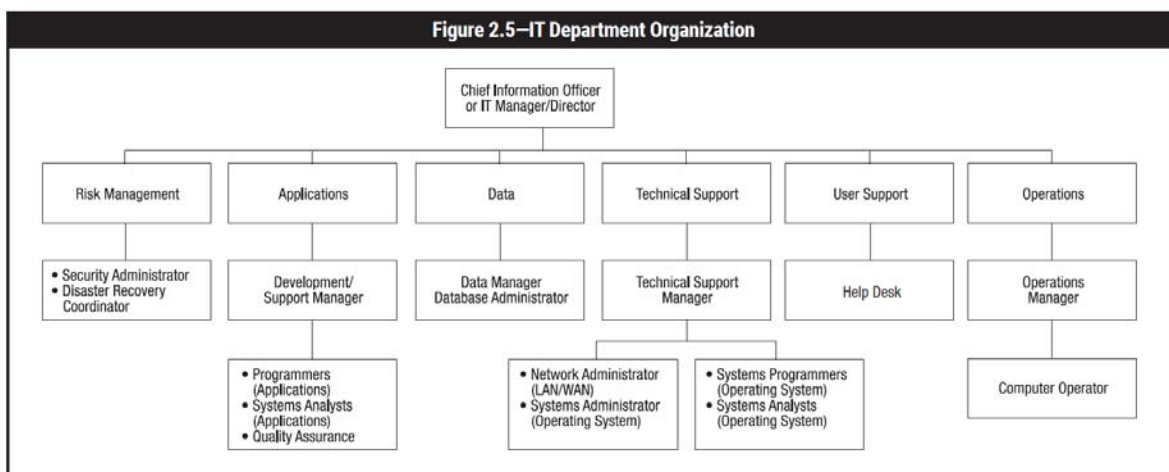


39

ISACA

39

IT ORGANIZATIONAL STRUCTURE AND RESPONSIBILITIES



40

ISACA

40

IT ORGANIZATIONAL STRUCTURE

Within an organization, the IT department can be structured in a variety of ways.

An organizational chart provides a clear definition of a department's hierarchy and lines of authority.

The IS auditor should compare observed roles and responsibilities with formal organizational structures and job descriptions.

ISACA

41

IT FUNCTIONS

Generally, the following IT functions should be reviewed by the IS auditor:

- Systems development management
- Project management
- Help or service desk administration
- End-user activities and their management
- Data management
- Quality assurance management
- Information security management

ISACA

42

IT FUNCTIONS (CONT'D)

Additionally, these functions should be reviewed by the IS auditor:

- Vendor and outsourcer management
- Infrastructure operations and maintenance
- Removable media management
- Data entry
- Supervisory control and data acquisition
- Systems and security administration
- Database administration
- Applications and infrastructure development and maintenance
- Network management

ISACA

43

SEGREGATION OF IT DUTIES

While actual job titles and organizational structures vary across enterprises, an IS auditor must obtain enough information to understand and document the relationships among various job functions, responsibilities and authorities.

The IS auditor must also assess the adequacy of SoD.

SoD limits the possibility that a single person will be responsible for functions in such a way that errors or misappropriations could occur undetected.

SoD is an important method to discourage and prevent fraudulent or malicious acts.



44

SOD GUIDELINES

Duties that should be segregated include:

- Asset custody
- Authorization capability
- Transaction recording

Both IS and end-user departments should be organized to meet SoD policies.



45

SOD GUIDELINES (CONT'D)

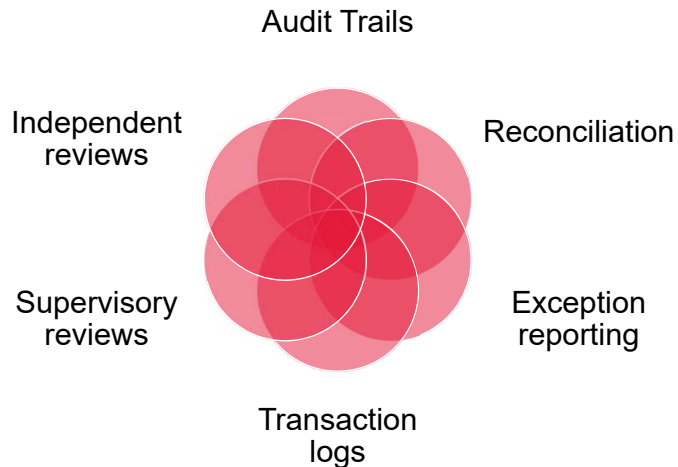
If adequate SoD does not exist, the following may occur with a lower likelihood of detection:

- Misappropriation of assets
- Misstated financial statements
- Inaccurate financial documentation (due to errors or irregularities)
- Improper use of funds or modification of data
- Unauthorized or erroneous modification of programs



46

COMPENSATING CONTROLS FOR LACK OF SOD



47

ISACA

47

AUDITING IT GOVERNANCE STRUCTURE AND IMPLEMENTATION

Some of the more significant indicators of potential problems include:

- Excessive costs
- Budget overruns
- Late projects
- High staff turnover
- Inexperienced staff
- Frequent HW/SW errors
- An excessive backlog of user requests
- Slow computer response time
- Numerous aborted or suspended development projects
- Unsupported or unauthorized HW/SW purchases
- Frequent HW/SW upgrades
- Extensive exception reports
- Exception reports that were not followed up
- Lack of succession plans
- A reliance on one or two key personnel
- Lack of adequate training

48

ISACA

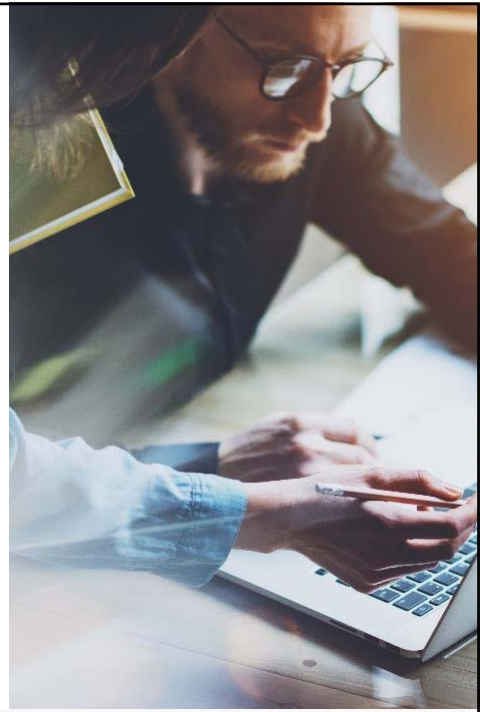
48

REVIEWING DOCUMENTATION

The following governance documents should be reviewed:

- IT strategies, plans and budgets
- Security policy documentation
- Organization/functional charts
- Job descriptions
- IT steering committee reports
- System development and program change procedures
- Operations procedures
- HR manuals
- QA procedures

49



49



ACTIVITY

The CFO and CIO have agreed to maximize the return on investment and lower the total cost of operations within the organization's IT operations to meet revenue goals and objectives. To implement this strategy, the IT department froze all hiring and procurement of equipment.

As the IS auditor, you notice that the domain administrators are also now the auditors of user account activities and authorizing changes to access file servers within the domain. What should you do?

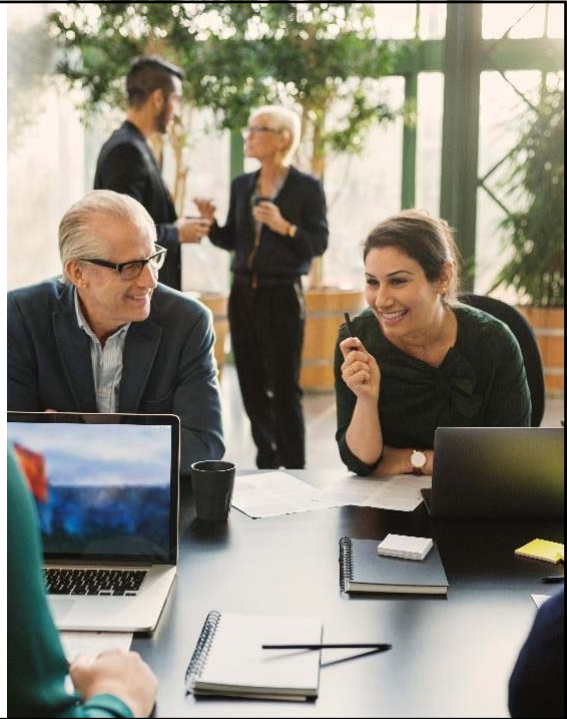


50

DISCUSSION QUESTION

An IS auditor reviewing an organization that uses cross-training practices should assess the risk of:

- A. dependency on a single person.
- B. inadequate succession planning.
- C. one person knowing all parts of a system.
- D. a disruption of operations.



51

ENTERPRISE ARCHITECTURE

ISACA

52

ENTERPRISE ARCHITECTURE

Enterprise architecture (EA) is a practice focused on documenting an organization's IT assets in a structured manner.

EA facilitates the understanding of, management of, and planning for IT investments through comparison of the current state and an optimized future state.

ISACA

53

ENTERPRISE ARCHITECTURE (CONT'D)

EA can be approached from one of two differing perspectives, as follows:

- Technology-driven EA — Seeks to clarify the complex technology choices faced by an organization in order to provide guidance on the implementation of various solutions.
- Business-driven EA — Attempts to understand the organization in terms of its core processes, and derive the optimum mix of technologies needed to support these processes.

ISACA

54

ACTIVITY

ABC Corporation has been missing critical infrastructure capabilities to meet new business agreements. The audit committee and CEO has requested Internal Audit to determine the causes of these failures.

As an IS auditor, what areas would you consider when scoping this audit?

What key governance element would best address the key risk realized during this project?



55

DISCUSSION QUESTION

Which of the following choices is the **PRIMARY** benefit of requiring a steering committee to oversee IT investment?

- A. To conduct a feasibility study to demonstrate IT value
- B. To ensure that investments are made according to business requirements
- C. To ensure that proper security controls are enforced
- D. To ensure that a standard development methodology is implemented



56

DISCUSSION QUESTION

As an outcome of information security governance, strategic alignment provides:

- A. security requirements driven by enterprise requirements.
- B. baseline security following good practices.
- C. institutionalized and commoditized solutions.
- D. an understanding of risk exposure.



57

ENTERPRISE RISK MANAGEMENT

ISACA

58

RISK MANAGEMENT

The process of risk management focuses on an enterprise's information resources.

To be effective, the process must begin with an understanding of senior management's appetite for risk.



59

RISK RESPONSE

Four possible responses to risk are:

- Avoidance — elimination of the cause of the risk
- Mitigation — reduction of the probability of a risk's occurrence or of its impact
- Transfer — sharing of risk with partners, such as through insurance or joint ventures
- Acceptance — formal acknowledgment of the presence of risk with a commitment to monitor it

A fifth response, rejection of risk through choosing to ignore it, is not considered effective risk management. The presence of this risk response should be a red flag for the IS auditor.

ISACA

60

DEVELOPING A RISK MANAGEMENT PLAN

Establish the purpose of the risk management program

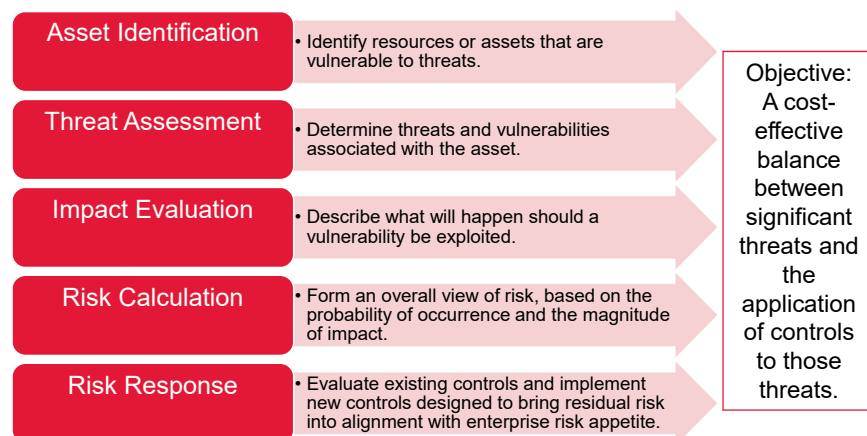
Assign responsibility for the risk management plan



61

61

RISK MANAGEMENT PROGRAM



ISACA

62

RISK ANALYSIS METHODS

Risk analysis is defined as a process by which frequency and magnitude of IT risk scenarios are estimated.

Three methods may be employed during risk analysis:

- Qualitative analysis methods — Descriptive rankings are used to describe risk likelihood and impact.
- Semi-quantitative analysis methods — Descriptive rankings are associated with numeric values.
- Quantitative analysis methods — Numeric values, for example, in the form of financial costs, are used to describe risk likelihood and impact.

Each of the three methods offers a perspective on risk, but it is important to acknowledge the assumptions incorporated into each risk analysis.

ISACA

63

DISCUSSION QUESTION

Which of the following factors should an IS auditor **PRIMARILY** focus on when determining the appropriate level of protection for an information asset?

- A. Results of a risk assessment
- B. Relative value to the business
- C. Results of a vulnerability assessment
- D. Cost of security controls

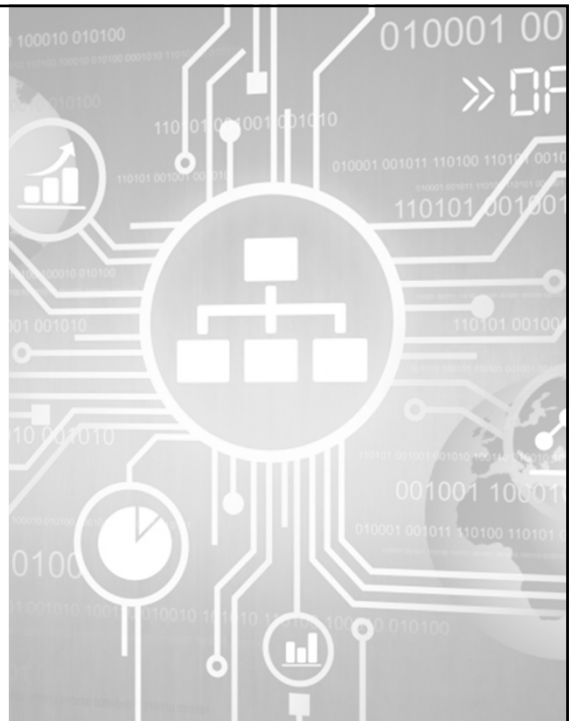


64

DISCUSSION QUESTION

When an organization's disaster recovery plan (DRP) has a reciprocal agreement, which of the following risk treatment approaches is being applied?

- A. Transfer
- B. Mitigation
- C. Avoidance
- D. Acceptance



65

MATURITY MODEL

ISACA

66

MATURITY MODELS

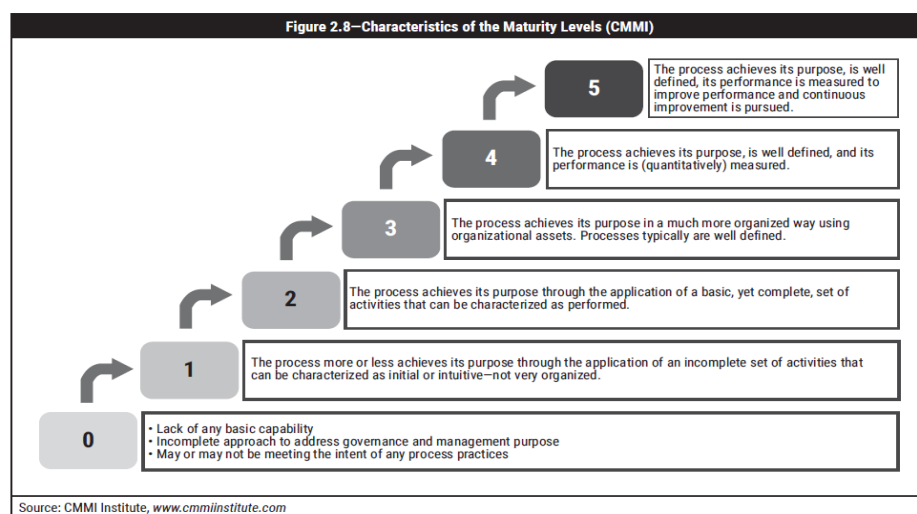
The IS auditor needs to understand how the development, implementation and integration of capability and maturity modeling quality tools, techniques and processes (TTPs) will facilitate and foster the quality of enterprise IT policies and procedures.

67



67

CAPABILITY MATURITY MODEL INTEGRATION



68

ISACA

68

LAWS, REGULATIONS AND INDUSTRY STANDARDS AFFECTING THE ORGANIZATION

ISACA

69

GOVERNANCE, RISK AND COMPLIANCE

GRC typically focuses on:

- Financial
- Legal



70

IMPACT OF LAWS, REGULATIONS AND INDUSTRY STANDARDS ON IS AUDIT

- Standards and procedures
- Assignment of responsibility to senior personnel
- Reliable background of staff
- Communication of procedures
- Compliance monitoring and auditing
- Consistent enforcement
- Appropriate response to an offense and prevention of similar offenses

71

ISACA

71

ISACA®

IT MANAGEMENT

72

72

IT RESOURCE MANAGEMENT

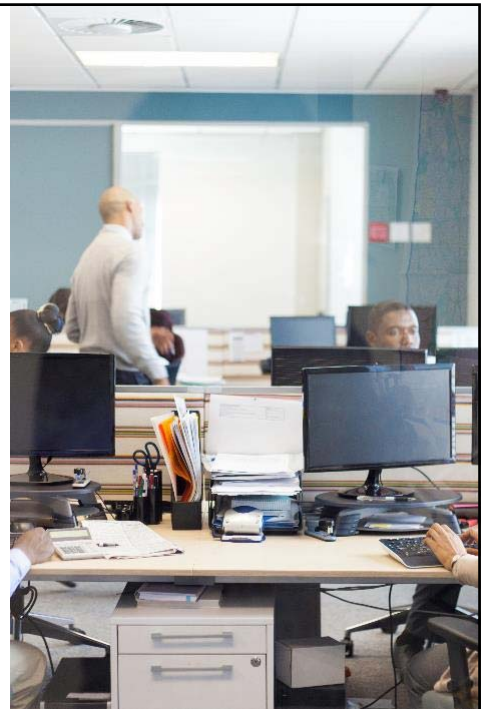
ISACA

73

IT RESOURCE MANAGEMENT

An IS auditor should understand an organization's investment and allocation practices to determine whether the enterprise is positioned to achieve the greatest value from the investment of its resources.

Where feasible, nonfinancial benefits should be made visible and tangible by using algorithms that transform them into monetary units to understand their impact and improve their analysis.



74

HR MANAGEMENT



ISACA

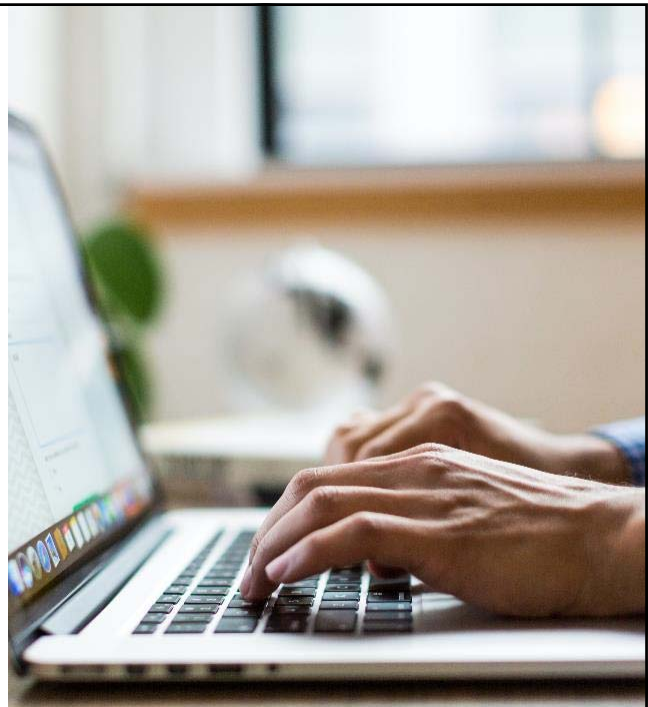
75

CHANGE MANAGEMENT

Organizational change management uses a defined and documented process to identify and apply technology improvements at both the infrastructure and application levels.

The IT department is the focal point for such changes and leads or facilitates the changes with senior management support.

Communication is an important component of change management, and end-users must be informed of the impact and benefits of changes.



76

FINANCIAL MANAGEMENT

The IS budget allows for an adequate allocation of funds and for forecasting, monitoring and analyzing financial information.

The budget should be linked to short- and long-range IT plans.

A “user-pays” scheme can improve application and monitoring of IS expenses and resources.

- In this arrangement, end users are charged for costs of IS services they receive.
- These charges are based on a standard formula and include such IS services as staff time, computer time and other relevant costs.

ISACA®

INFORMATION SECURITY

Information security governance is the responsibility of the board of directors and executive management.

Information security governance is a subset of corporate governance, providing strategic direction for security activities and ensuring that objectives are achieved.

An information security program comprises the leadership, organizational structures and the processes that safeguard information.



INFORMATION SECURITY (CONT'D)

The information security governance framework will generally consist of:

- A security strategy linked with business objectives
- Security policies that address strategy, controls and regulation
- Standards to ensure that procedures and guidelines comply with policies
- An effective security organizational structure without conflicts of interest
- Monitoring procedures to ensure compliance and provide feedback on effectiveness



79

INFORMATION SECURITY MANAGEMENT

Information security management provides the lead role to ensure that the organization's information and the information processing resources under its control are properly protected.



80

80

IT SERVICE PROVIDER ACQUISITION AND MANAGEMENT

ISACA

81

IT SERVICE FUNCTION STRATEGIES

Define the IT function to be outsourced.

Describe the service levels required and minimum metrics to be met.

Know the desired level of knowledge, skills and quality of the expected service provider desired.

Know the current in-house cost information to compare with third-party bids.

Conduct due diligence reviews of potential service providers.

Confirm any architectural considerations to meeting contractual or regulatory requirements.

Insourced

Outsourced

Hybrid

Onsite

Offsite

Offshore

ISACA

82

OUTSOURCING PRACTICES AND STRATEGIES

Figure 2.9—Advantages, Disadvantages and Business Risk, and Risk Reduction Options Related to Outsourcing

Possible Advantages	Possible Disadvantages and Business Risk	Risk Reduction Options
- Commercial outsourcing companies can achieve economies of scale through the deployment of reusable component software. - Outsourcing vendors are likely to be able to devote more time and to focus more effectively and efficiently on a given project than in-house staff. - Outsourcing vendors are likely to have more experience with a wider array of problems, issues and techniques than in-house staff. - The act of developing specifications and contractual agreements using outsourcing services is likely to result in better specifications than if developed only by in-house staff. - Because vendors are highly sensitive to time-consuming diversions and changes, feature creep or scope creep is substantially less likely with outsourcing vendors.	- Costs exceeding customer expectations - Loss of internal IT experience - Loss of control over IT - Vendor failure (ongoing concern) - Limited product access - Difficulty in reversing or changing outsourced arrangements - Deficient compliance with legal and regulatory requirements - Contract terms not being met - Lack of loyalty of contractor personnel toward the customer - Disgruntled customers/employees as a result of the outsource arrangement - Service costs not being competitive over the period of the entire contract - Obsolescence of vendor IT systems - Failure of either company to receive the anticipated benefits of the outsourcing arrangement - Reputational damage to either or both companies due to project failures - Lengthy, expensive litigation - Loss or leakage of information or processes	- Establishing measurable, partnership-enacted shared goals and rewards - Software escrow to ensure maintenance of the software - Using multiple suppliers or withholding a piece of business as an incentive - Performing periodic competitive reviews and benchmarking/benchtrading - Implementing short-term contracts - Forming a cross-functional contract management team - Including contractual provisions to consider as many contingencies as can reasonably be foreseen

83

IS Auditors should review:

- Quality programs (ISO/IEC 15504 (SPICE), CMMI, ITIL and ISO methodologies)
- Review SLAs

ISACA

83

OUTSOURCING PRACTICES AND STRATEGIES

Incorporate service quality expectations, including usage of *ISO/IEC 15504 (Software Process Improvement and Capability Determination [SPICE])*, CMMI, ITIL or ISO methodologies.

Ensure adequate contractual consideration of access control/security administration, whether vendor- or owner-controlled.

Ensure that violation reporting, and follow-up are required by the contract.

Ensure any requirements for owner notification and cooperation with any investigations.

Ensure that change/version control and testing requirements are contractually required for the implementation and production phases.

Ensure that the parties responsible and the requirements for network controls are adequately defined and any necessary delineation of these responsibilities established.

State specific, defined performance parameters that must be met; for example, minimum processing times for transactions or minimum hold times for contractors.

84

ISACA

84

OUTSOURCING PRACTICES AND STRATEGIES

Incorporate capacity management criteria.

Provide contractual provisions for making changes to the contract.

Provide a clearly defined dispute escalation and resolution process.

Ensure that the contract indemnifies the company from damages caused by the organization responsible for the outsourced services.

Require confidentiality agreements protecting both parties.

Incorporate clear, unambiguous "right to audit" provisions, providing the right to audit vendor operations (e.g., access to facilities, access to records, right to make copies, access to personnel, provision of computerized files) as they relate to the contracted services.

Ensure that the contract adequately addresses business continuity and disaster recovery provisions, and appropriate testing.

Establish that the confidentiality, integrity and availability (sometimes referred to as the CIA triad) of organization-owned data must be maintained, and clearly establish the ownership of the data.

85

ISACA

85

OUTSOURCING PRACTICES AND STRATEGIES

Require that the vendor comply with all relevant legal and regulatory requirements, including those enacted after contract initiation

Establish ownership of intellectual property developed by the vendor on behalf of the customer

Establish clear warranty and maintenance periods

Provide software escrow provisions

Protect intellectual property rights

Comply with legislation

Establish clear roles and responsibilities between the parties.

Require that the vendor follow the organization's policies, including its information

Follow the organization's security policy (unless the vendor's policies have been agreed to in advance by the organization)

Require the vendor to identify all subcontract relationships and requiring the organization's approval to change subcontractors

86

ISACA

86

GLOBALIZATION PRACTICES AND STRATEGIES

The IS auditor can assist in this process by ensuring that IT management considers the following risk and audit concerns when defining the globalization strategy and completing the subsequent transition to remote offshore locations:

- Legal, regulatory and tax issues
- Continuity of operations
- Personnel
- Telecommunication issues
- Cross-border and cross-cultural issues
- Planned globalization and/or important expansion

87

ISACA

87

OUTSOURCING AND THIRD-PARTY AUDIT REPORTS

An IS auditor should be familiar with the following:

- Management assertions and how well these address the services being provided by the service provider
- SSAE 18 reports (SOC 1, SOC 2 and SOC 3 reports)
- Additional third-party audit reports such as penetration tests and security assessments. Note: Third-party assessments should be performed by independent, objective and competent third parties.
- How to obtain the report, review it and present results to management for further action

88



88

CLOUD GOVERNANCE

Ensure that IT is aligned with the business, systems are secure, and risk is managed is challenging in any environment and even more complex in a third-party relationship.

Governance activities such as goal setting, policy and standard development, defining roles and responsibilities, and managing risk must include special considerations when dealing with cloud technology and its providers.

Policies must be modified or developed to address the process of sourcing, managing and discontinuing the use of cloud services

ISACA

89

GOVERNANCE IN OUTSOURCING

Ensure contractual viability through continuous review, improvement and benefit gain to both parties.

Include an explicit governance schedule to the contract.

Manage the relationship to ensure that contractual obligations are met through SLAs and operating level agreements (OLAs).

Identify and manage all stakeholders, their relationships and expectations.

Establish clear roles and responsibilities for decision making, issue escalation, dispute management, demand management and service delivery.

Allocate resources, expenditures and service consumption in response to prioritized needs.

Continuously evaluate performance, cost, user satisfaction and effectiveness.

Communicate across all stakeholders on an ongoing basis.



90

MONITORING AND MANAGING THIRD-PARTY SERVICES

Monitor

- Performance levels
- Service reports
- Security incidents
- Audit trails and records of security events, operational problems, failures, tracing of faults and disruptions related to the service delivered
- Resolve and manage any identified problems

Manage

- Changes to the organization
- Changes in the third-party services
- Changes to physical location of service facilities
- Change of vendors or subcontractors

91

ISACA

91

IT PERFORMANCE MONITORING AND REPORTING

92

ISACA

92

IT PERFORMANCE MONITORING AND REPORTING

Business contribution including, but not limited to, financials

Performance against the strategic business and IT plan

Risk and compliance with regulations

Internal and external user satisfaction with service levels

Key IT processes, including solution and service delivery

Future-oriented activities (e.g., emerging technology, reusable infrastructure, business and IT personnel skill sets)

93



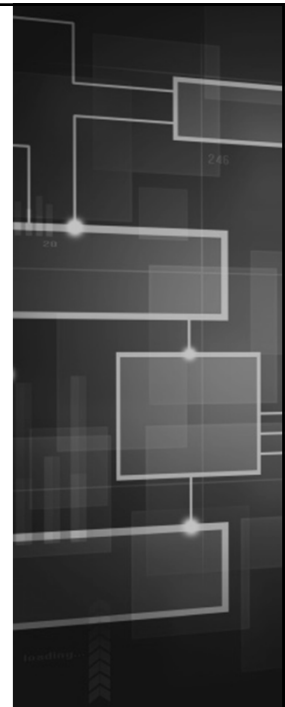
93

PERFORMANCE OPTIMIZATION

A variety of improvement and optimization methodologies are available that complement simple, internally developed approaches. These include:

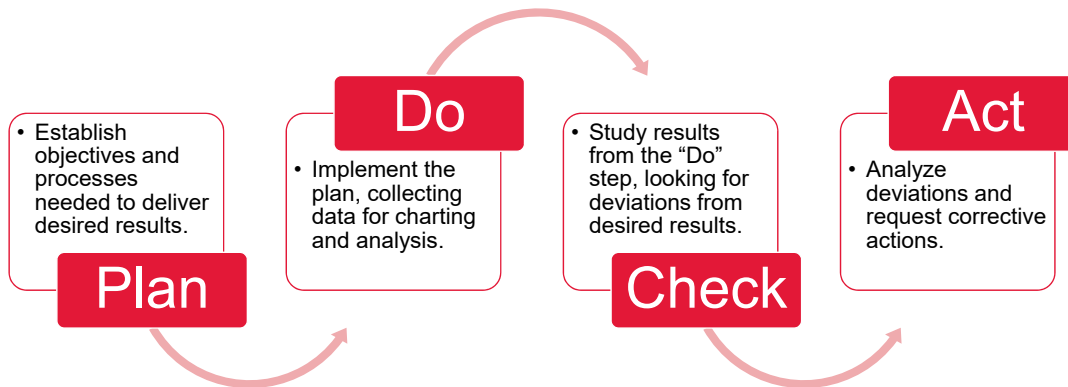
- Continuous improvement methodologies, such as the PDCA cycle
- Comprehensive best practices, such as ITIL
- Frameworks, such as COBIT

94



94

THE PDCA METHOD



ISACA

95

TOOLS AND TECHNIQUES

Six Sigma	• A quantitative process analysis, defect reduction and improvement approach
IT BSC	• A process management evaluation technique that can be effectively applied to assess IT functions and processes
KPI	• A measure that determines how well a process is performing in enabling a goal to be reached
Benchmarking	• A systematic approach to comparing enterprise performance against competitors to learn methods
BPR	• The thorough analysis and redesign of business processes to establish a better performing structure with cost savings
Root Cause Analysis	• The process of diagnosis to establish the origins of events so that controls can be developed to address these causes
Life Cycle Cost-benefit	• Assessment of life cycle, life cycle cost and benefit analysis to determine strategic direction for IT systems

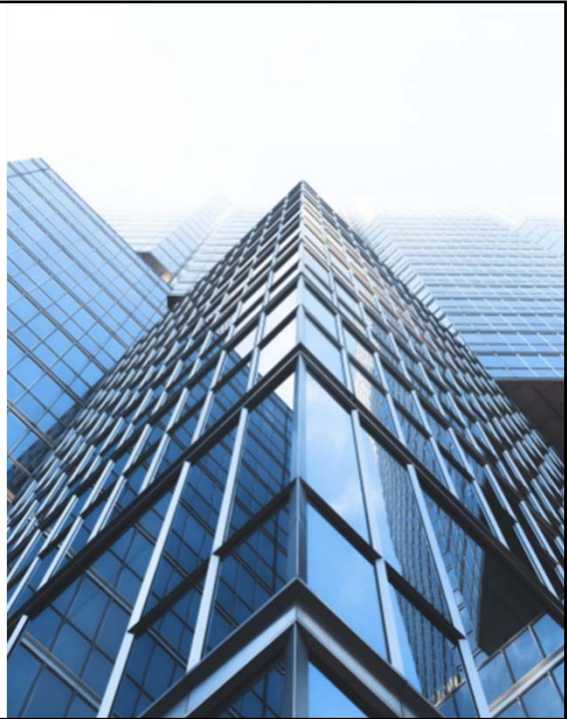
ISACA

96



ACTIVITY

As an IS auditor, if you were reviewing the cloud sourcing area, what would you look at to determine alignment?



97



DISCUSSION QUESTION

While reviewing a quality management system (QMS) the IS auditor should **PRIMARILY** focus on collecting evidence to show that:

- A. quality management systems (QMSs) comply with good practices.
- B. continuous improvement targets are being monitored.
- C. standard operating procedures of IT are updated annually.
- D. key performance indicators (KPIs) are defined.



98

IT BALANCED SCORECARD

The IT balanced scorecard (BSC) is a management evaluation technique that can be applied to the EGIT process.

It goes beyond traditional financial evaluation by measuring:

- Customer (or user) satisfaction
- Internal operational processes
- The ability to innovate

ISACA

99

IT BALANCED SCORECARD (CONT'D)

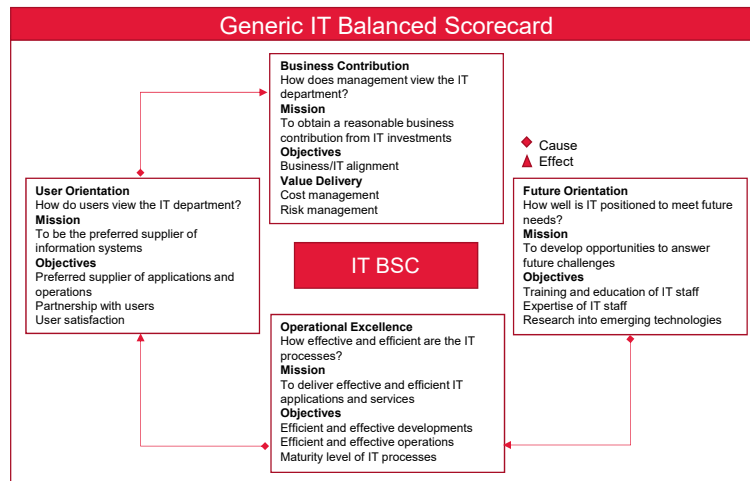
IT BSC objectives serve to:

- Establish a method for management reporting to the board.
- Foster consensus among stakeholders about IT strategic aims.
- Demonstrate the effectiveness of IT.
- Facilitate communication about the performance, risk and capabilities of IT.

ISACA

100

EXAMPLE OF AN IT BSC



Source: ISACA, *IT Governance Domain Practices and Competencies: Measuring and Demonstrating the Value of IT*, USA, 2005, figure 7

ISACA

101

ACTIVITY

You have been assigned to evaluate how IT resources are categorized and managed. During interviews, you realize that specific benchmarks and measures have not been established with regard to:

- Personnel skills and experience
- Direction of outsourcing of IT services

Without having key performance indicators defined, what problems are likely to occur when managing outsourced service providers?

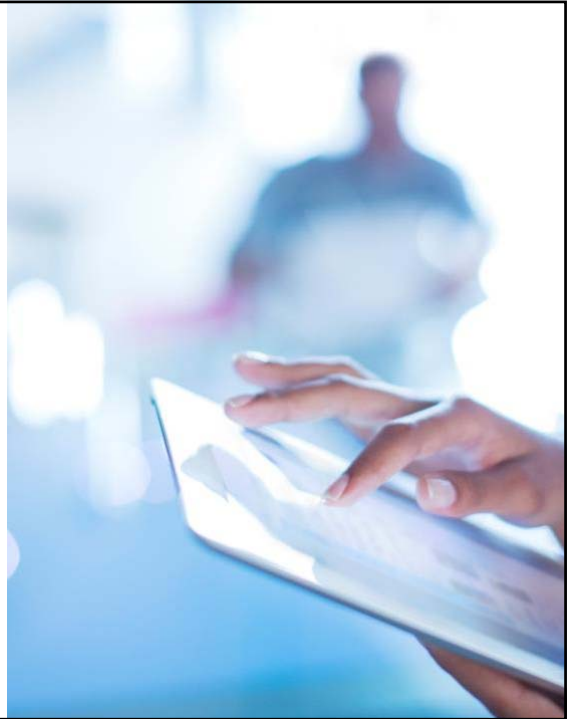


102

DISCUSSION QUESTION

Which of the following is the **MOST** important IS audit consideration when an organization outsources a customer credit review system to a third-party service provider? The provider:

- A. claims to meet or exceed industry security standards.
- B. agrees to be subject to external security reviews.
- C. has a good market reputation for service and experience.
- D. complies with security policies of the organization.



103

DISCUSSION QUESTION

Before implementing an IT balanced scorecard (BSC), an organization must:

- A. deliver effective and efficient services.
- B. define key performance indicators.
- C. provide business value to IT projects.
- D. control IT expenses.



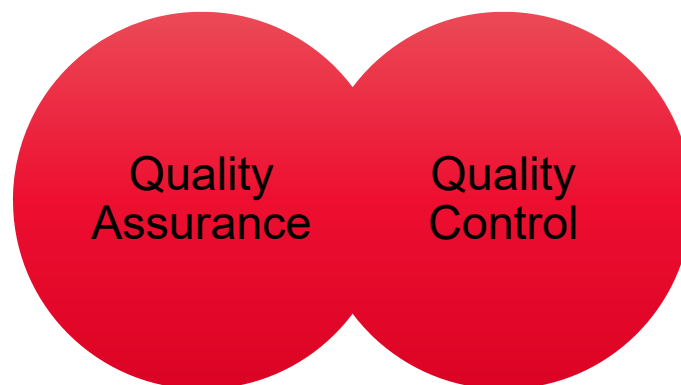
104

QUALITY ASSURANCE AND QUALITY MANAGEMENT OF IT

ISACA

105

QUALITY ASSURANCE



ISACA

106

QUALITY MANAGEMENT

Areas of control for quality management may include:

- Software development, maintenance and implementation
- Acquisition of hardware and software
- Day-to-day operations
- Service management
- Security
- HR management
- General administration

107

ISACA

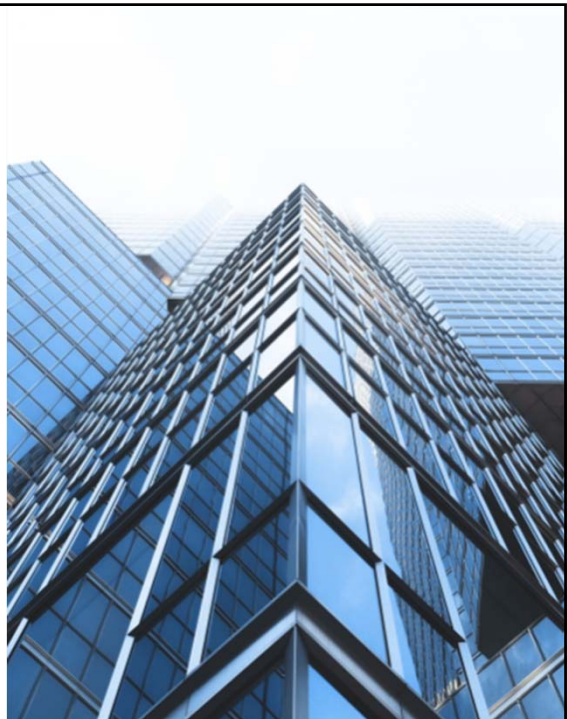
107



ACTIVITY

Many of ABC corporation's software products are not found to meet EU Privacy Directives. Furthermore, many of the software products have numerous injection and cross-site scripting vulnerabilities.

What is the best way to address these vulnerabilities?

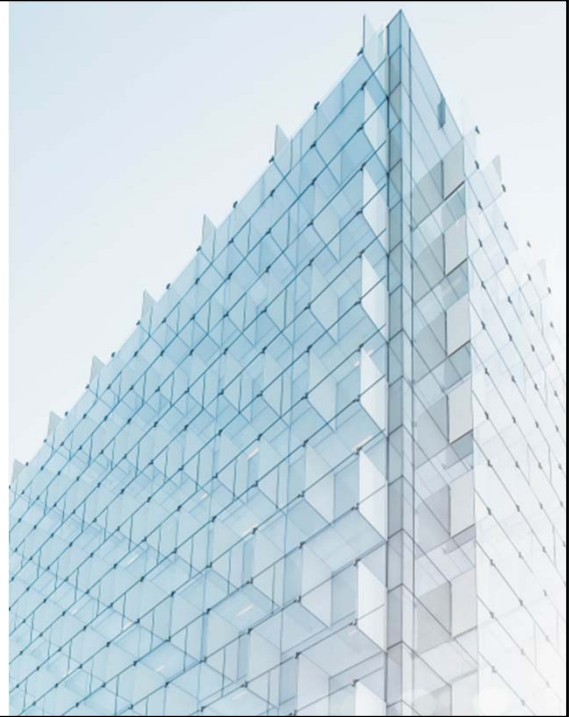


108

DISCUSSION QUESTION

An IS auditor is performing a review of the software quality management process in an organization. The **FIRST** step should be to:

- A. verify how the organization follows the standards.
- B. identify and report the controls currently in place.
- C. review the metrics for quality evaluation.
- D. request all standards that have been adopted by the organization.



109

PRACTICE QUESTIONS

110

ISACA

110

PRACTICE QUESTION

Effective IT governance ensures that the IT plan is consistent with the organization's:

- A. Business plan.
- B. Audit plan.
- C. Security plan.
- D. Investment plan.

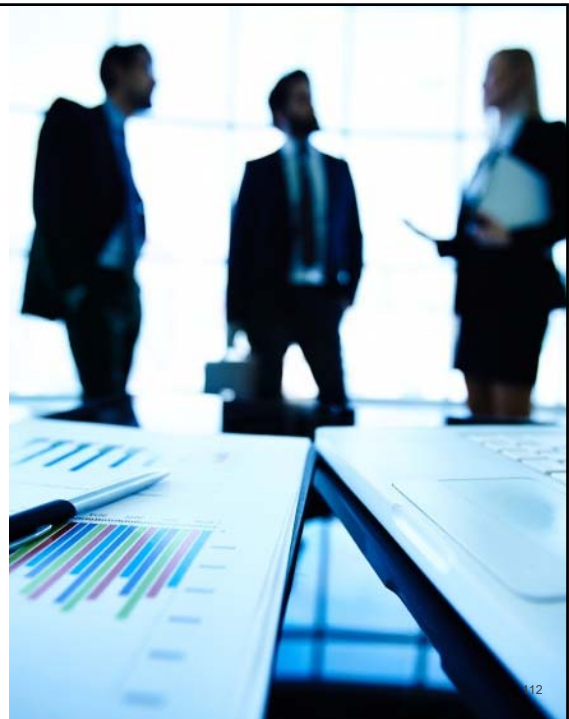


111

PRACTICE QUESTION

Responsibility for the governance of IT should rest with the:

- A. IT strategy committee.
- B. Chief information officer.
- C. Audit committee.
- D. Board of directors.

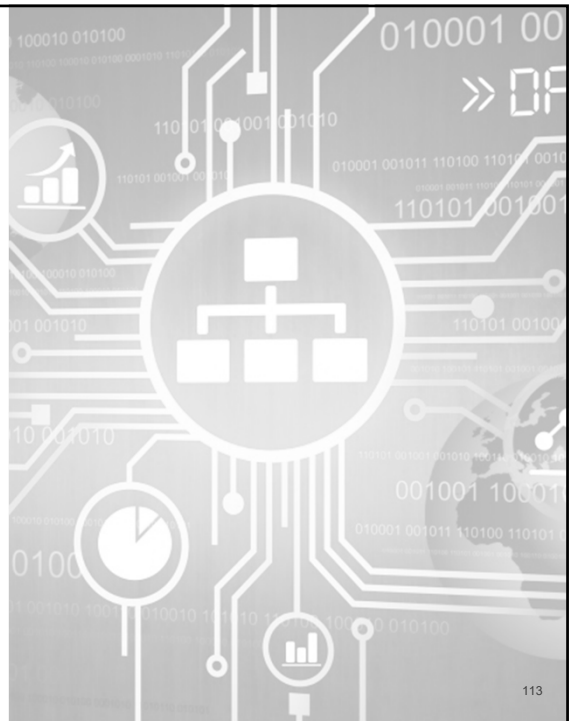


112

PRACTICE QUESTION

When developing a security architecture, which of the following steps should be executed **FIRST**?

- A. Developing security procedures
- B. Defining a security policy
- C. Specifying an access control methodology
- D. Defining roles and responsibilities

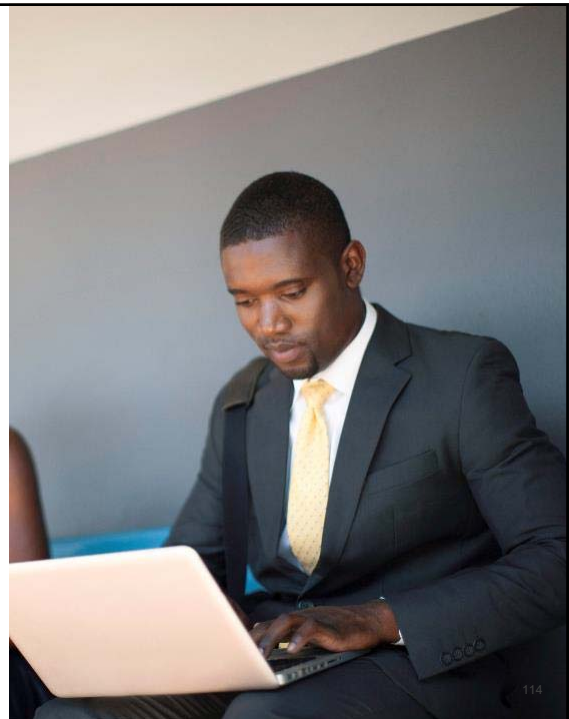


113

REVIEW QUESTION

The **PRIMARY** benefit of an enterprise architecture initiative is to:

- A. Enable the organization to invest in the most appropriate technology.
- B. Ensure security controls are implemented on critical platforms.
- C. Allow development teams to be more responsive to business requirements.
- D. Provide business units with greater autonomy to select IT solutions that fit their needs.



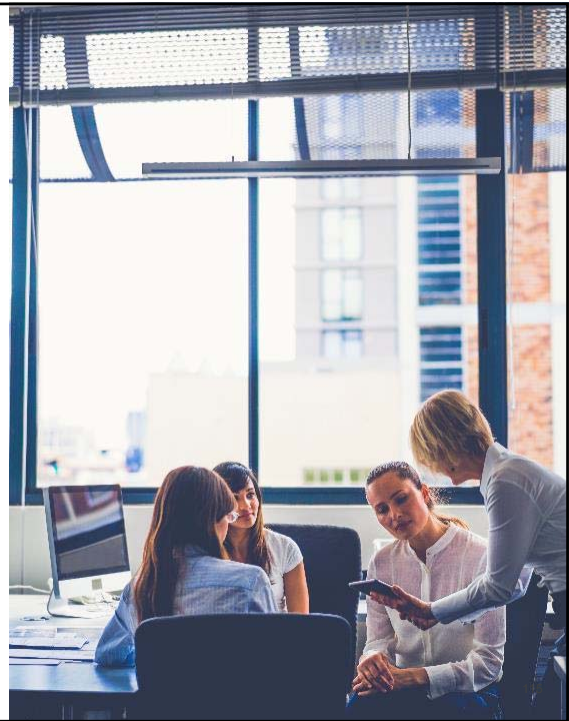
114



REVIEW QUESTION

An IS auditor is assigned to review IT structures and activities recently outsourced to various providers. Which of the following should the IS auditor determine **FIRST**?

- A. An audit clause is present in all contracts.
- B. The service level agreement of each contract is substantiated by appropriate key performance indicators.
- C. The contractual warranties of the providers support the business needs of the organization.
- D. At contract termination, support is guaranteed by each outsourcer for new outsourcers.



115

DOMAIN 2 REVIEW

As an IS auditor, you should now be able to:

- Evaluate the IT strategy for alignment with the organization's strategies and objectives.
- Evaluate the effectiveness of IT governance structure and IT organizational structure.
- Evaluate the organization's management of IT policies and practices.
- Evaluate the organization's IT policies and practices for compliance with regulatory and legal requirements.
- Evaluate IT resource and portfolio management for alignment with the organization's strategies and objectives.
- Evaluate the organization's risk management policies and practices.
- Evaluate IT management and monitoring of controls.



116

DOMAIN 2 REVIEW

- Evaluate the monitoring and reporting of IT key performance indicators (KPIs).
- Evaluate whether IT supplier selection and contract management processes align with business requirements.
- Evaluate whether IT service management practices align with business requirements.
- Conduct periodic review of information systems and enterprise architecture. Evaluate data governance policies and practices.
- Evaluate the information security program to determine its effectiveness and alignment with the organization's strategies and objectives.
- Evaluate potential opportunities and threats associated with emerging technologies, regulations, and industry practices.

